

PR Audit Report

Repository	dipak-shaaki/demo-git-test-2
PR Number	#3
Risk Level	MEDIUM

PR Audit Report

Summary

This PR adds a new reports API endpoint and a service layer that can optionally fetch external data and write a generated report to disk.

What the Developer Was Trying to Do

The developer appears to be implementing report generation for a user, with optional enrichment from an external URL, and persisting the resulting report as a text file under a local `reports/` directory.

Security Issues (Bandit + Dependabot + SonarCloud)

1) `requests.get()` is called without a timeout

Finding: Bandit flagged a medium-severity issue in `fetch_external_data()` because the outbound HTTP request has no timeout.

Full function with issue

```
def fetch_external_data(url: str):  
    # risky external call
```

```
response = requests.get(url) # <- ISSUE HERE
return response.text
```

Why this is problematic

Without a timeout, the request can hang indefinitely if the remote service is slow or unresponsive. That can tie up worker threads/processes, degrade availability, and create a denial-of-service risk under load.

Corrected version

```
def fetch_external_data(url: str):
    # risky external call
    response = requests.get(url, timeout=10)
    return response.text
```

Official documentation

- Bandit B113: https://bandit.readthedocs.io/en/1.9.4/plugins/b113_request_without_timeout.html
- Requests timeout docs: <https://requests.readthedocs.io/en/latest/user/quickstart/#timeouts>

Code Quality Issues (Ruff + SonarCloud)

No Ruff or SonarCloud findings were reported for this PR.

Teammate Comments Summary

No teammate review comments were provided.

Overall Risk Assessment

- **Risk Level:** MEDIUM
- **Reason:** The change introduces external network access without a timeout, which can impact service reliability if the remote endpoint is slow or unavailable.